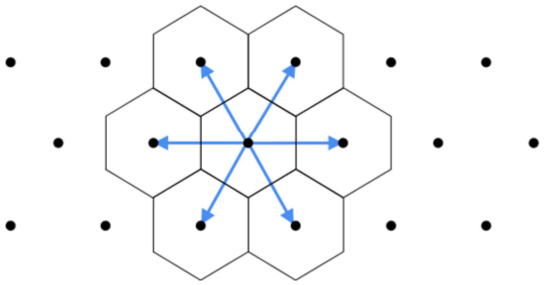
Lattice based





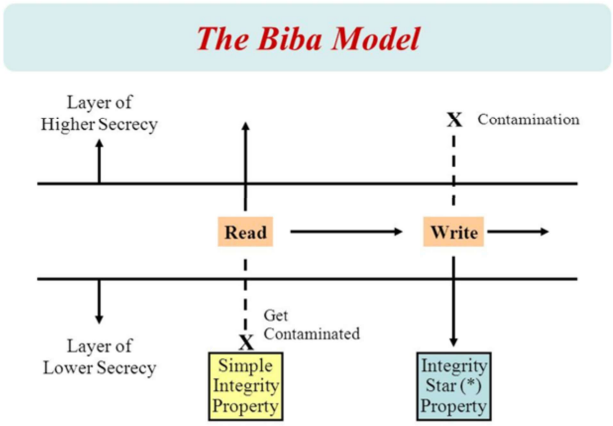
© 2018 Al-Nafi. All Rights Reserved.

In computer security, **lattice-based access control** (**LBAC**) is a complex access control model based on the interaction between any combination of **objects** (such as resources, computers, and applications) and **subjects** (such as individuals, groups or organizations).

In this type of label-based mandatory access control model, a lattice is used to define the levels of security that an object may have and that a subject may have access to. The subject is only allowed to access an object if the security level of the subject is greater than or equal to that of the object.

Mathematically, the security level access may also be expressed in terms of the lattice (a partial order set) where each object and subject have a greatest lower bound (meet) and least upper bound (join) of access rights. For example, if two subjects *A* and *B* need access to an object, the security level is defined as the meet of the levels of *A* and *B*. In another example, if two objects *X* and *Y* are combined, they form another object *Z*, which is assigned the security level formed by the join of the levels of *X* and *Y*. LBAC is also known as a label-based access control (or *rule-based access control*) restriction as opposed to role-based access control (RBAC).

The Biba Model



© 2018 Al-Nafi. All Rights Reserved.

The Biba model is designed to address data integrity and does not address data confidentiality. Like Bell–LaPadula, Biba is also a lattice-based model with multiple levels. It defines similar but slightly different modes of access (e.g., observe, modify) and also describes interactions between subjects and objects. Where Biba differs most obviously is that it is an integrity model; it focuses on ensuring that the integrity of information is being maintained by preventing corruption.

At the core of the model is a multilevel approach to integrity designed to prevent unauthorized subjects from modifying objects. Access is controlled to ensure that objects maintain their current state of integrity as subjects interact with them. Instead of the confidentiality levels used by Bell–LaPadula, Biba assigns integrity levels to subjects and objects depending on how trustworthy they are considered to be.

Like Bell–LaPadula, Biba considers the same modes of access but with different results. The model defines three properties, the ss-property and the *-property as in BLP, but also includes a new property, the invocation property.

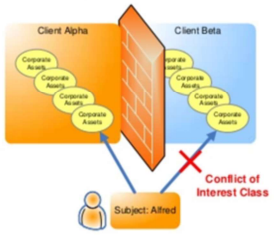
Simple Integrity property: A subject cannot observe an object of lower integrity (no read down)
Star property: A subject cannot modify an object of higher integrity (no write up)
Invocation property: A subject cannot send logical service requests to an object of higher integrity

Brewer-Nash Model AKA Chinese Wall Model

Brewer-Nash Security Model (a.k.a. Chinese Wall)

Brewer-Nash security model is used to implement dynamically changing access permissions.

- A "wall" is defined by a set of rules that ensures no subject from one side of the wall can access objects on the other side of the wall.

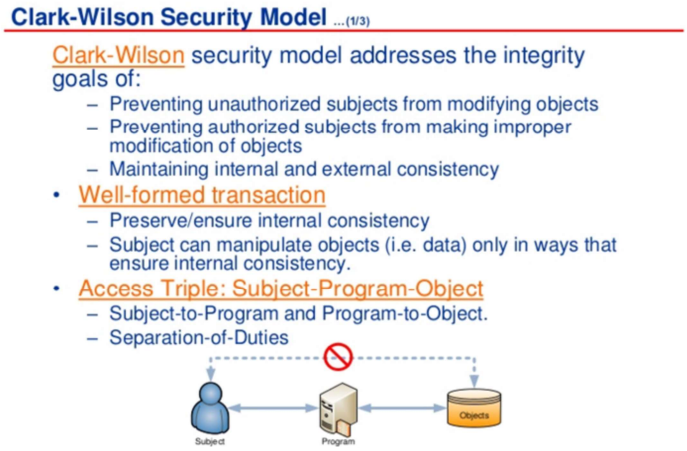


© 2018 Al-Nafi. All Rights Reserved.

Brewer and Nash

This model focuses on preventing conflict of interest when a given subject has access to objects with sensitive information associated with two competing parties. The principle is that users should not access the confidential information of both a client organization and one or more of its competitors. At the beginning, subjects may access either set of objects. Once, however, a subject accesses an object associated with one competitor, they are instantly prevented from accessing any objects on the opposite side. This is intended to prevent the subject from sharing information inappropriately between the two competitors even unintentionally. It is called the Chinese Wall Model because, like the Great Wall of China, once on one side of the wall, a person cannot get to the other side. It is an unusual model in comparison with many of the others because the access control rules change based on subject behavior.

Clark-Wilson Security Model



© 2018 Al-Nafi. All Rights Reserved.

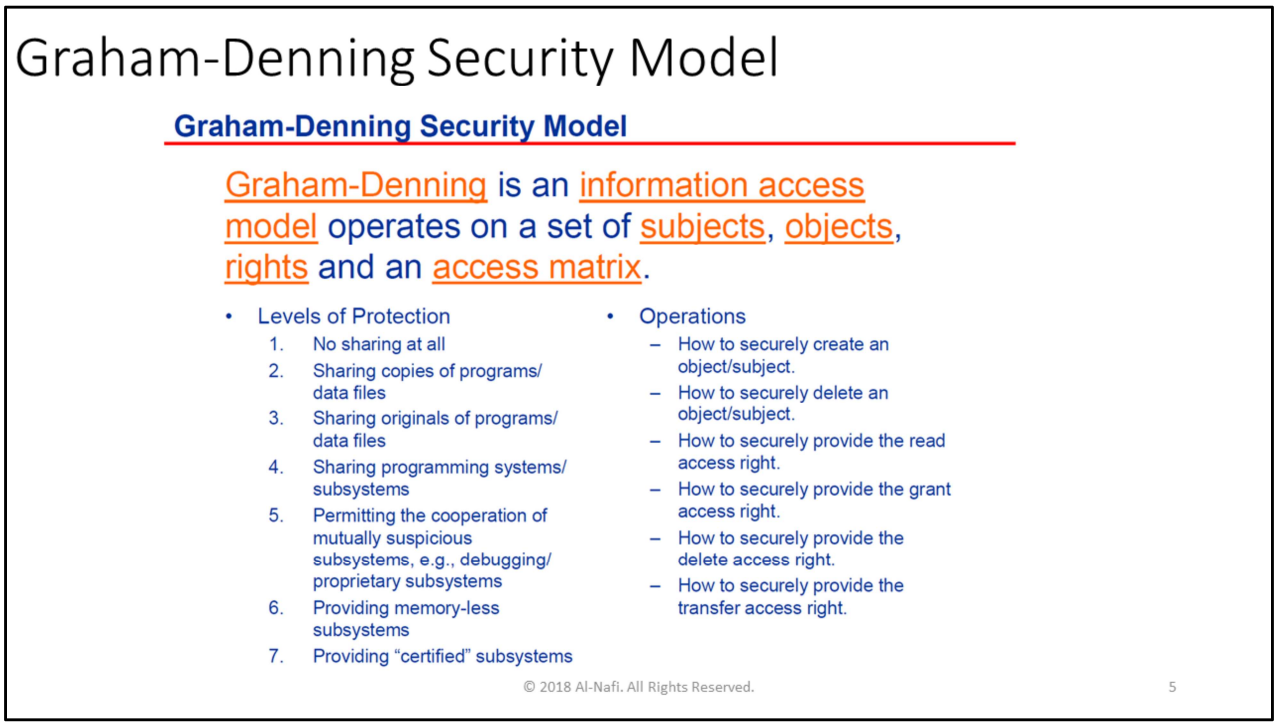
Clark–Wilson

Biba only addresses one of three key integrity goals. The Clark–Wilson model improves on Biba by focusing on integrity at the transaction level and addressing three major goals of integrity in a commercial environment.

To address the second goal of integrity, Clark and Wilson realized that they needed a way to prevent authorized subjects from making undesirable changes. This required that transactions by authorized subjects be evaluated by another party before they were committed on the model system. This provided separation of duties where the powers of the authorized subject were limited by another subject given the power to evaluate and complete the transaction. To address internal consistency (or consistency within the model system itself), Clark and Wilson recommended a strict definition of well-formed transactions.

In other words, the set of steps within any transaction would need to be carefully designed and enforced. Any deviation from that expected path would result in a failure of the transaction to ensure that the model system's integrity was not compromised. To control all subject and object interactions, Clark–Wilson establishes a system of subject–program–object bindings such that the subject no longer has direct access to the object. Instead, this is done through a program with

access to the object. This program arbitrates all access and
ensures that every interaction between subject and object follows a defined set of rules. The program provides for subject authentication and identification and limits all access to objects under its control.



Graham–Denning

Graham–Denning is primarily concerned with how subjects and objects are created, how subjects are assigned rights or privileges, and how ownership of objects is managed. In other words, it is primarily concerned with how a model system controls subjects and objects at a very basic level where other models simply assumed such control.

The Graham–Denning access control model has three parts: a set of objects, a set of subjects, and a set of rights. The subjects are composed of two things: a process and a domain. The domain is the set of constraints controlling how subjects may access objects. Subjects may also be objects at specific times. The set of rights govern how subjects may manipulate the passive objects.

This model describes eight primitive protection rights called commands that subjects can execute to have an effect on other subjects or objects.

The eight basic rules under Graham–Denning govern the following:

1. Secure object creation
2. Secure object deletion
3. Secure subject creation

4. Secure subject deletion
5. Secure provisioning of read access right
6. Secure provisioning of grant access right
7. Secure provisioning of delete access right
8. Secure provisioning of transfer access right

Graham-Denning Security Model continued…

Access Control Matrix specifying modes of access

- Subject-Object
- One row per subject
- One column per object

		Objects									
		S_1	S_2	S_3	S_4	S_5	O_1	O_2	O_3	O_4	O_5
Subjects	S_1	Cntrl	---	---			rwx	rw-	---	---	---
	S_2	---	Cntrl	---			---	---	--x	---	---
	S_3	---	---	Cntrl	r-x		---	---	---	---	---
	S_4	---	---	---	Cntrl		---	r-x	---	---	r-x
	S_5	---	---	---		Cntrl	---	r-x	---	---	---

© 2018 Al-Nafi. All Rights Reserved.

Harrison, Ruzzo, Ullman (HRU)

A model similar to Graham-Denning Model

© 2018 Al-Nafi. All Rights Reserved.

Harrison, Ruzzo, Ullman (HRU)

This model is very similar to the Graham–Denning model, and it is composed of a set of generic rights and a finite set of commands. It is also concerned with situations in which a subject should be restricted from gaining particular privileges. To do so, subjects are prevented from accessing programs, or subroutines, that can execute a particular command (to grant read access for example) where necessary.

Security Control



© 2018 Al-Nafi. All Rights Reserved.

Security controls are safeguards or countermeasures that mitigate risks to confidentiality, integrity, or availability in a system or operating environment. Controls may impact or modify the behavior of people, process, or technology. They may be directly applied or inherited from another system or organization.

Security Control Types

- Preventive controls: Reduce likelihood or impact of an undesirable event occurring
- Detective controls: Identify an undesirable event or collect information about it
- Corrective controls: Reduce or eliminate the impact of an undesirable event that has occurred

© 2018 Al-Nafi. All Rights Reserved.

Security Controls Classification

Controls can be classified by how they are applied:

- Management: Policy- or human-driven controls
- Operational: Process-driven controls
- Technical: Controls applied to technology

© 2018 Al-Nafi. All Rights Reserved.